

PAYSECURE CYBER READINESS POSTURE PLAN

1. Business Context Analysis

PaySecure is a UK-based fintech start-up offering a digital wallet and payment gateway integrated with e-commerce platforms, enabling secure online transactions and fund transfers. Its lean structure spans software engineering, product development, compliance, marketing, and customer support, supported by cloud infrastructure and an agile team.

SWOT Analysis

Strengths	Weaknesses	Opportunities	Threats
User-friendly wallet interface, Strong founding team, Agile delivery	Limited brand recognition, Small user base, Constrained resources as a start-up	Growth in digital payments, Fintech partnerships, Integration with emerging technologies (e.g. open banking, AI fraud detection)	Cybersecurity incidents, Regulatory change, Competition from established players (Revolut, GoCardless, Checkout.com)

Key stakeholders are customers (user experience and data protection), regulators (compliance and consumer protection), investors (growth potential), and staff (clarity of objectives). PaySecure's ISMS scope covers all information assets involved in delivering its wallet and payment services: cloud infrastructure, customer data, internal operations, and third-party integrations.

2. Governance Framework Development

Governance is structured around five defined roles: the Founder/CEO (vision, funding, overall accountability), Head of Development/CTO (technical architecture, security oversight), Head of Operations/COO (process and service delivery), Head of Finance/CFO (financial risk and reporting), and a dedicated Compliance Officer (regulatory adherence, internal audit, risk framework ownership, staff training).

PaySecure adopts a hybrid risk ownership model. Each business unit head owns risk within their function (a federated model), while the Head of Development acts as steward of the ISMS to ensure consistency, and the Compliance Officer retains oversight of enterprise-wide risk reporting (a centralised element). This balances functional accountability with coordinated oversight, appropriate for a start-up scaling its operations.

PaySecure's risk appetite is moderate for strategic and operational risk, to allow room for innovation and growth, but low to very low for financial, cybersecurity, compliance, and reputational risk, reflecting the regulated nature of payment services.

3. Risk Assessment

3.1 Risk Assessment Methodology and Justification

Several recognised methodologies exist for information security risk assessment. ISO/IEC 27005 provides a holistic, organisation-wide process covering people, process, and technology, and is designed to integrate directly with an ISO 27001 ISMS. NIST SP 800-30 is a more technically-focused methodology, well suited to assessing IT infrastructure risk in detail but less oriented toward business governance. OCTAVE is asset- and workshop-driven, focusing on critical assets and stakeholder-led risk identification, and is best suited to larger organisations with dedicated risk teams.

For PaySecure, ISO/IEC 27005 is the most appropriate methodology. As a start-up pursuing ISO 27001 certification (Section 8), aligning its risk assessment approach directly with 27005 avoids duplicating effort, and its scalability suits an organisation still building out formal risk resource. NIST SP 800-30 is used as a supporting reference for the technical risk register below, given its detailed likelihood/impact scoring conventions.

3.2 Risk Matrix

ID	Risk	Likelihood	Impact	Exposure	Owner
RP1	Data breaches	High	High	High	CEO
RP2	Unauthorised cloud access	High	High	High	Head of Development

ID	Risk	Likelihood	Impact	Exposure	Owner
RP3	Insider threats	Medium	High	Medium-High	Head of Development
RP4	Social engineering attacks	High	Medium	Medium-High	Head of Development
RP5	Non-compliance with regulation	Medium	High	Medium-High	Compliance Officer

Likelihood and impact are rated Low/Medium/High based on threat intelligence and PaySecure's transaction volumes; exposure ratings are differentiated rather than uniform, reflecting that social engineering and insider threats, while serious, currently carry a marginally lower combined exposure than direct data breaches or cloud misconfiguration given existing baseline controls.

3.3 Prioritisation and Treatment

Prioritisation criteria reflect PaySecure's regulatory environment: financial risk, customer impact, regulatory obligation, operational resilience, and asset/vendor criticality, ranked in that order. The treatment decision rule mitigates all high-exposure risks, mitigates or transfers medium-exposure risks (e.g. via cyber insurance), and accepts and monitors low-exposure risks.

3.4 Return on Security Investment (ROSI)

To justify security spend to leadership, PaySecure should quantify expected return using Annualised Loss Expectancy (ALE) and ROSI, following the SANS/CSO Online quantitative model (Kohen, 2017): $ALE = \text{Single Loss Expectancy (SLE)} \times \text{Annual Rate of Occurrence (ARO)}$; $ROSI = ((ALE \times \text{Mitigation Ratio}) - \text{Cost of Control}) / \text{Cost of Control}$.

Worked example for RP1 (Data Breaches): estimated SLE of £150,000 per breach (incident response, notification, and reputational cost), with an ARO of 0.4 (one breach expected every 2.5 years without controls) gives $ALE = £150,000 \times 0.4 = £60,000$. Implementing encryption and multi-factor authentication is estimated to mitigate 75% of this risk, at an annual control cost of £15,000. $ROSI = ((£60,000 \times 0.75) - £15,000) / £15,000 = 2.0$, a 200% return, providing a clear, defensible business case for the investment.

3.5 Risk Treatment Plan (ISO 27001-mapped)

ID	Risk	ISO 27001 Annex A Control	Treatment
RP1	Data breaches	A.8.24 Use of cryptography; A.8.5 Secure authentication	Mitigate
RP2	Unauthorised cloud access	A.8.16 Monitoring activities; A.5.15 Access control	Mitigate
RP3	Insider threats	A.5.3 Segregation of duties; A.8.16 Monitoring activities	Mitigate
RP4	Social engineering	A.6.3 Awareness and training	Mitigate
RP5	Regulatory non-compliance	A.5.31 Legal, statutory, regulatory requirements	Mitigate

4. Implementation of Security Controls

Control documentation should identify and classify each control, confirm alignment to ISO 27001 Annex A, and be version-controlled to prevent outdated use.

4.1 Access Control Policy

Scope: all employees, contractors, and systems handling PaySecure data. Policy statement: access is granted on least-privilege and need-to-know principles (A.5.15, A.5.18). Roles and responsibilities: the Head of Development approves system-level access; line managers approve role-based access. Compliance: quarterly access reviews and immediate revocation on role change or exit. Review: annually or after a material incident.

4.2 Asset Management Policy

Purpose: to identify, classify, and protect PaySecure's information assets (A.5.9 Inventory of assets, A.5.10 Acceptable use, A.5.11 Return of assets). Scope: covers hardware, software, cloud services, and data assets. Classification: assets are tiered Critical, High, Medium, Low based on sensitivity and business impact, with Critical assets (e.g. payment processing systems, customer PII) subject to the strictest controls. Ownership: every asset has a named owner

responsible for its protection. Handling: acceptable use rules apply to all company-issued and BYOD devices. Offboarding: all assets and access are returned or revoked on staff exit. Review: the asset register is reviewed quarterly.

5. Incident Response Plan Creation

PaySecure's incident response plan follows the standard lifecycle: preparation, identification, notification, containment, eradication, recovery, and post-incident review.

Incident Management Policy

- Purpose: ensure timely identification, management, and resolution of incidents to minimise operational, customer, and regulatory impact.
- Scope: applies to all employees, contractors, and third parties with access to PaySecure systems or data.
- Roles: leadership oversight; an incident coordinator manages the response; engineering/DevOps provide technical remediation; the Compliance Officer manages regulatory reporting.
- Classification: severity levels from Low to Critical determine escalation speed, response time, and communication requirements.
- Reporting channels: a defined internal reporting channel, with mandatory immediate escalation for Critical and High severity incidents.
- Communication: internal updates scaled to severity; external communication requires Compliance sign-off.
- Regulatory requirements: incidents involving personal data are assessed for ICO notification within 72 hours under UK GDPR.
- Third parties: suppliers must notify PaySecure promptly of any incident affecting shared systems or data.
- Documentation: all incidents are logged and retained for audit and regulatory review.
- Post-incident review: root cause analysis and control improvements are completed within a defined timeline.
- Training: annual staff training and periodic tabletop exercises.
- Governance: a named policy owner and annual review cycle.

6. Training and Awareness Program

Training keeps staff current on compliance obligations and secure practice, supporting both regulatory adherence and a security-conscious culture. PaySecure's programme includes mandatory onboarding training for all staff, contractors, and relevant third parties; role-specific training delivered by department heads; continuous refresher training on a quarterly and annual cycle; and ad hoc training triggered by major incidents or regulatory change. Department heads (Compliance, Development, Operations, Finance) deliver role-specific content, with completion tracked centrally by Compliance.

7. Compliance and Regulatory Considerations

PaySecure's compliance programme rests on four pillars. Regulatory compliance covers FCA authorisation and licensing, Anti-Money Laundering and Know Your Customer obligations, UK GDPR data protection requirements, and consumer protection standards. Operational compliance covers governance and risk management, compliance training, monitoring and auditing, and vendor management. Technology compliance covers secure systems design, IT governance, and secure electronic payment processing. Reporting and documentation compliance covers regulatory reporting, record-keeping, and document management, each essential to demonstrating compliance during regulatory review.

8. Continuous Improvement Strategy

PaySecure's roadmap to ISO/IEC 27001 certification proceeds through seven steps: conduct a gap analysis against Annex A; develop and document a structured ISMS; implement the Annex A controls identified as applicable in the risk treatment plan; conduct regular internal audits; hold management reviews of ISMS performance; address non-conformities ahead of certification audit; and engage an accredited certification body for external audit and certification. This roadmap should be reviewed annually alongside the risk register and RoSI calculations, ensuring security investment continues to be evidenced and justified as the business scales.

References

- Kohen, I. (2017, September 25). How to calculate your return on security investment. CSO Online. <https://www.csoonline.com/article/563097/how-to-calculate-your-return-on-security-investments.html>
- International Organization for Standardization. (2022). ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements. ISO.
- International Organization for Standardization. (2018). ISO/IEC 27005:2018 — Information technology — Security techniques — Information security risk management. ISO.
- National Institute of Standards and Technology. (2012). Guide for conducting risk assessments (NIST Special Publication 800-30, Rev. 1). U.S. Department of Commerce.
- SISA Information Security. (2022). Comparison between ISO 27005, OCTAVE and NIST SP 800-30. <https://www.sisainfosec.com/blogs/comparison-between-iso-27005-octave-nist-sp-800-30-sisa-blog/>
- Drata. (n.d.). Understanding ISO 27001 controls: A guide to Annex A. <https://drata.com/learn/iso-27001/controls-annex-a>
- Information Commissioner's Office. (n.d.). Guide to the UK GDPR. <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/>
- Tunggal, A. T. (2025). What is an information security policy? UpGuard. <https://www.upguard.com/blog/information-security-policy>
- Diligent. (2025). How to document internal controls in 7 steps. <https://www.diligent.com/resources/blog/documenting-internal-controls>
- Financial Conduct Authority. (n.d.). Regulation for fintech firms. <https://www.fca.org.uk>